



## Full Duplex Authentication®

Mitigar Ataques de Phishing, Navegador Dentro de Navegador y Proxy Fraudulentos

### Abstracto

Este informe técnico profundiza sobre Full Dúplex Authentication®, una tecnología de seguridad de vanguardia diseñada para abordar las crecientes amenazas de phishing, navegador en navegador y ataques de proxy no autorizados. Para sentar las bases para comprender Full Duplex Authentication®, primero exploraremos la naturaleza de estas amenazas cibernéticas y posteriormente profundizaremos en el enfoque innovador descrito en la [patente estadounidense 11,245,526](#).

### Introducción

La seguridad en línea es primordial a medida que las amenazas cibernéticas evolucionan en el panorama digital contemporáneo. Los ataques de phishing, navegador en navegador y proxy fraudulentos han reemplazado los métodos sofisticados empleados por actores maliciosos para comprometer las credenciales de los usuarios y la información confidencial. Full Dúplex Authentication® surge como una solución robusta para contrarrestar estas amenazas.

### ¿Qué es la autenticación??

La autenticación es el proceso de verificar una identidad digital en línea. Cuando se asocia a un ser humano con una identidad digital, se le pide que proporcione credenciales que demuestren que es quien afirma ser.

Hay tres métodos estándar de validación. El primer método puede ser algo que un usuario sepa, como una contraseña, un Número de Identificación Personal (PIN) o un código de



acceso de un solo uso (OTP). El segundo método es algo que normalmente tiene un usuario, como un dispositivo registrado, un token digital en ese dispositivo o un dispositivo de hardware en particular, como un Yubikey. El tercer método es algo que es el usuario, que será algún elemento biométrico como el reconocimiento facial o la huella dactilar. Si un usuario realiza más de una acción para la verificación, esto se conoce como autenticación multifactor (MFA). Para garantizar el más alto nivel de seguridad al autenticar una identidad digital, los tres métodos de validación deben ejecutarse cada vez que un usuario se autentica en un sistema o servicio.

## Comprender las amenazas cibernéticas a la autenticación

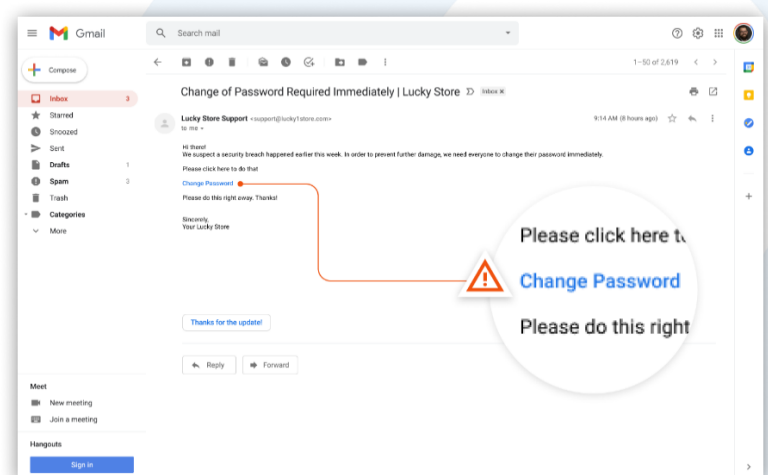
**70 a 90 por ciento**  
de todas las violaciones  
de seguridad maliciosas  
se debe a la ingeniería  
social y ataques de  
phishing.

Durante varios años, los delincuentes han enfocado sus esfuerzos de ciberataque en el robo de credenciales en línea. Según Roger Grimes, experto principal en seguridad de KnowB4, [70 a 90 por ciento de todas las violaciones de seguridad maliciosas se debe a la ingeniería social y ataques de phishing](#). Según Verizon DBIR, en 2023, 74% de las infracciones involucraron el elemento humano, incluyendo ataques de ingeniería social como el phishing. Se ha vuelto más fácil para los delincuentes obtener los credenciales de un usuario utilizando diversas técnicas de ingeniería social que

llevar a cabo sofisticados ataques de fuerza bruta.

Estos son algunos de los métodos más comunes utilizados por los delincuentes para obtener credenciales de usuario de manera fraudulenta y eludir la autenticación multifactor:

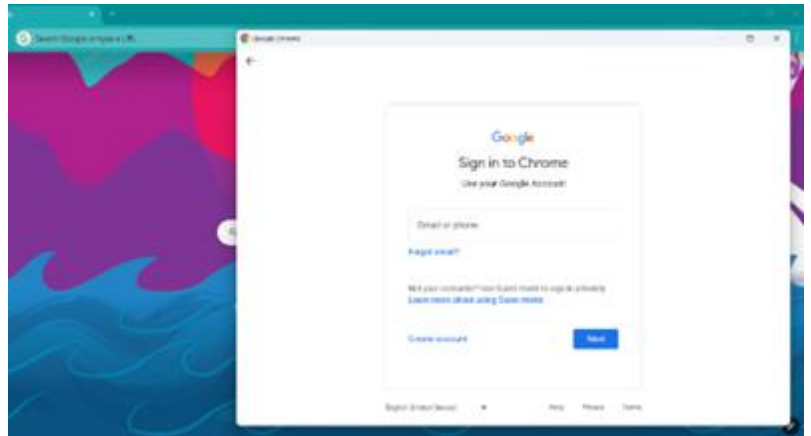
- **Ataques Phishing:** El phishing implica intentos fraudulentos de obtener información confidencial haciéndola pasar por una entidad confiable. El phishing, que suele entregarse a través de correos electrónicos o sitios web impostores, aprovecha de la psicología humana para engañar a los usuarios y conseguir que revelen datos confidenciales. Las variaciones de phishing incluyen Smishing, que implica el uso de SMS, y Vishing, que implica piratear restablecimientos de contraseñas enviados por correo de voz. Quishing



implica el uso de códigos QR para guiar a los usuarios a través de la trampa. El phishing se utiliza a menudo junto con la suplantación de correos electrónicos y sitios web. El usuario recibe un correo electrónico falso que parece provenir de una organización legítima como un banco, una empresa de telecomunicaciones o incluso un gigante tecnológico como Amazon, Microsoft, Apple o Google. El correo electrónico indicará un problema con la cuenta, lo que requerirá que el usuario inicie sesión. Cuando el usuario hace clic en el hipervínculo, a menudo pierde la URL, que es diferente del sitio al que cree que se dirige. Una vez que el usuario ingresa sus credenciales, su cuenta ha sido comprometida.

- **Ataques Browser-en-Browser:**

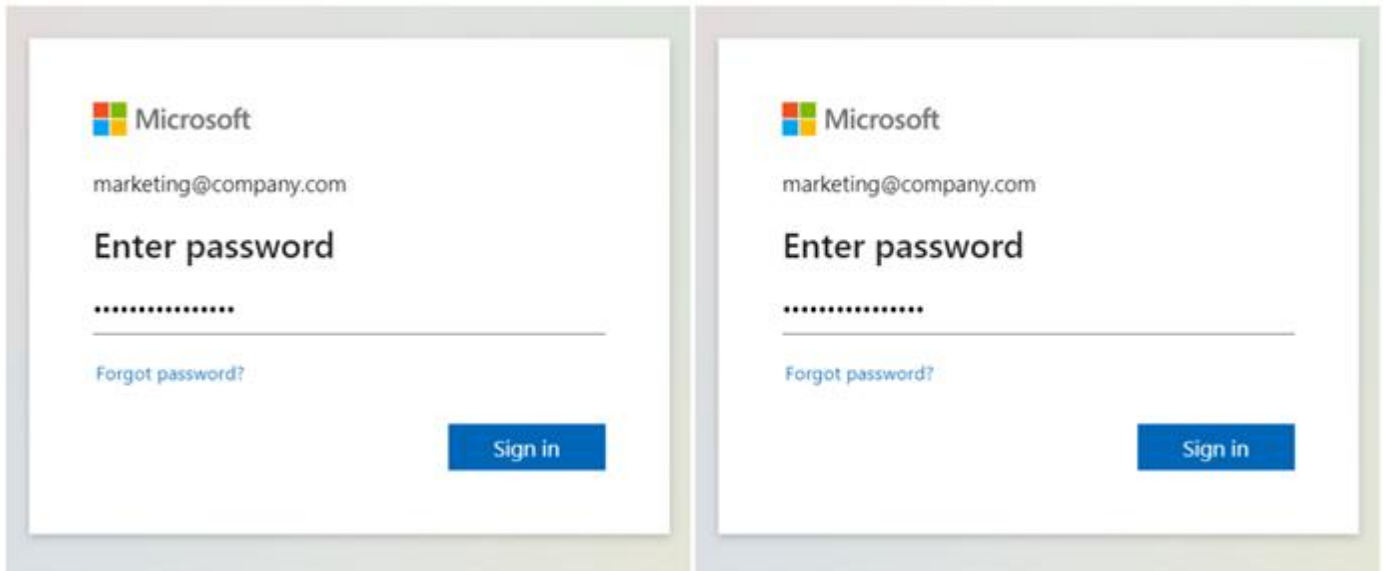
Los ataques de navegador en navegador ocurren cuando una entidad maliciosa inyecta código en un sitio web legítimo, comprometiendo la seguridad del navegador del usuario. Este método permite a los atacantes robar información confidencial o ejecutar acciones no autorizadas en nombre del usuario. Este tipo



de ataque es difícil de detectar para el usuario. El usuario no puede notar el cambio en la URL porque los diálogos entre navegadores no muestran una URL. Una vez que el usuario ingresa sus credenciales, su cuenta ha sido comprometida.

- **Ataques de Proxy Deshonestos:** Los ataques de proxy fraudulentos implican la interceptación de la comunicación entre el usuario y un servidor web mediante servidores proxy maliciosos. Los atacantes pueden espiar datos confidenciales, manipular maliciosamente la comunicación y robar la contraseña al iniciar sesión. Este tipo de ataque es el más difícil de detectar porque los delincuentes pueden emular fácilmente servicios populares como Office365, Okta y las redes sociales. Hay "kits" disponibles en Internet, y cualquier delincuente con habilidades informáticas básicas puede comenzar a robar credenciales ingresando un nombre de dominio. Los diálogos de inicio de sesión que presenta el proxy son casi imposibles de detectar para un usuario. Para Microsoft Office365 y Azure, el problema es peor. Incluso cuando los usuarios hayan activado Microsoft MFA, el proxy esperará la confirmación de que el usuario realizó MFA y luego tomará el token que se devuelve en la secuencia HTTP. El

hacker pegará esto en otro navegador y ahora tendrá acceso al entorno MS Office de la organización.



*¿Puedes identificar lo que es falso?*

## Full Dúplex Authentication®

Incluso si el mundo dejara de utilizar métodos de verificación basados en el conocimiento, esto no evitaría los tipos de ataques de phishing e ingeniería social que ocurren hoy en día. Esto se debe a que todos los métodos de autenticación que se utilizan hoy en día tienen un defecto fundamental: el flujo de verificación es unidireccional. El servicio de autenticación solicitante desafiará al usuario a realizar las acciones necesarias para demostrar su validez.



El usuario debe poder impugnar el servicio de autenticación solicitante para demostrar su validez.

Esto permite que todos los malos actores se hagan pasar por un servicio legítimo para engañar al usuario para que proporcione la contraseña, el token digital o la verificación biométrica del dispositivo.

Identité® desarrolló y patentó Full Dúplex Authentication® para abordar este defecto fundamental en la autenticación. El concepto de Full Dúplex Authentication® está resumido en la [patente estadounidense](#)

[11.245.526](#). Este patente introduce un método de autenticación novedoso que implica comunicación bidireccional y cifrada entre el usuario y el sistema de autenticación. A diferencia de la autenticación unidireccional tradicional, Full Dúplex Authentication® garantiza un intercambio continuo y dinámico de información durante todo el flujo de autenticación.

## Como Funciona Full Dúplex Authentication®

Un servidor de autenticación, que Identité llama NoPass™, abreviatura de "sin contraseña", crea una relación segura con un servicio de terceros. Los servicios de terceros recopilan la identificación del usuario y comienzan el proceso de autenticación inicial. Estos servicios incluyen Microsoft AD y Azure, herramientas SSO como Okta, VPN, Citrix o cualquier aplicación o portal que requiera que un usuario se autentique. Un servidor NoPass™ tiene algunas formas diferentes de integrarse en servicios de terceros.

- **SSO Federado:** el servidor NoPass™ está configurado para actuar como proveedor de identidad para servicios como Microsoft Azure/AD o cualquier otra herramienta de autenticación SSO como Okta, PingIdentity, KeyCloak, etc.
- **RADIUS:** el servidor NoPass™ está configurado para actuar como un cliente de RADIUS
- **API:** el servidor NoPass™ está configurado para establecer comunicaciones seguras con portales web y aplicaciones móviles.

El servidor NoPass™ interactúa con un usuario a través de aplicaciones que se ejecutan en iOS, Android, Windows y MacOS. Estos se obtienen a través de las tiendas de aplicaciones públicas, generalmente cuando un usuario se registra por primera vez para la autenticación NoPass™. La aplicación recibe notificaciones automáticas seguras del servidor NoPass™ cada vez que un usuario solicita autenticación en un servidor de terceros configurado para usar NoPass™ Full Dúplex Authentication®. La aplicación contiene un conjunto único de credenciales para cada portal web o servicio que el usuario haya registrado. Estas credenciales están cifradas, pero por sí solas, no se pueden utilizar para obtener acceso a un servicio, como en el caso de un ataque de repetición. Los usuarios pueden hacer una copia de seguridad de sus credenciales y sincronizarlas con otros dispositivos si la política de seguridad lo permite.

## Flujo de Registro Full Dúplex Authentication®

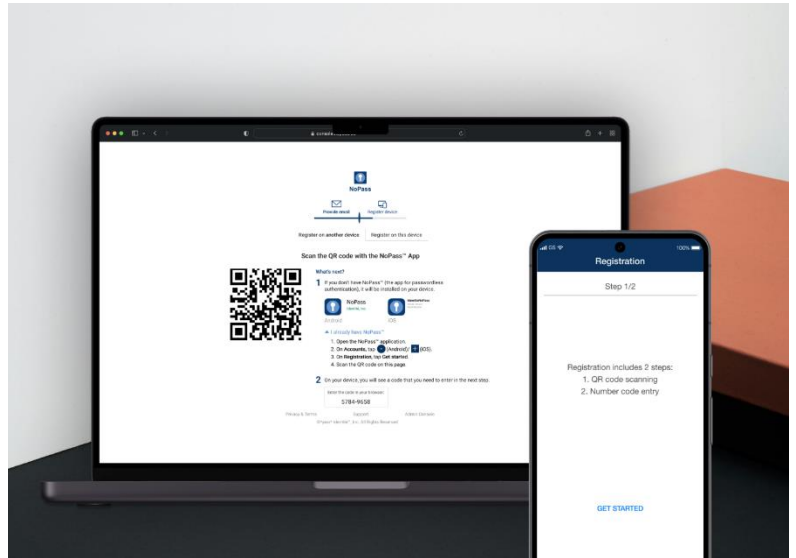
Para registrarse en Full Dúplex Authentication®, los usuarios deben autenticarse utilizando el flujo de autenticación nativo del servicio. Normalmente, esto se hace proporcionando un nombre de usuario y una contraseña. Una vez que el servicio verifica la autenticación, se

dirige al usuario a una interfaz de registro para Full Dúplex Authentication®. El registro involucrará al usuario y un dispositivo como una PC, Mac o teléfono inteligente.

Dependiendo de la política de seguridad establecida en el servidor de autenticación NoPass™, el usuario elegirá el dispositivo e instalará una pequeña aplicación. El propósito de la aplicación es mantener una credencial Full Dúplex Authentication® para cada cuenta de usuario en cada servicio en el que el usuario se registra. Se admiten varias cuentas de usuario en el mismo servicio.

La interfaz de registro para la autenticación Full Dúplex permitirá al usuario escanear un código QR o tocar o hacer clic en un botón Continuar, lo que invoca una instalación local de la aplicación Full Dúplex Authentication®.

Supongamos que el usuario instala la aplicación de autenticación en un dispositivo distinto al que muestra la interfaz de registro. En ese caso, se le pedirá al usuario que confirme un código de 8 dígitos para asegurarse de que está en posesión del dispositivo secundario. Una vez confirmada la confirmación del registro, el usuario es autenticado y regresado al servicio para continuar su tarea sin más interrupciones. Cuando los usuarios cierran sesión y regresan al servicio, no se les solicita una contraseña. En lugar de ello, pasan por el flujo Full Dúplex Authentication®.

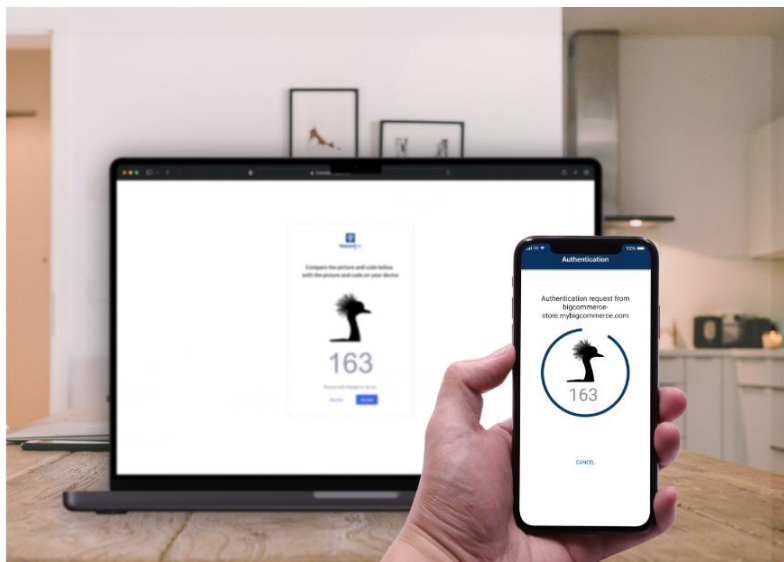


Cuando la aplicación Full Dúplex Authentication® está instalada en un dispositivo, reconocerá y utilizará factores de autenticación adicionales si están disponibles. Estos pueden incluir tokens biométricos y de hardware como Yubikey. La aplicación Full Dúplex Authentication® también se puede configurar para usar un PIN. Estos factores adicionales mitigan los riesgos en caso de pérdida o robo del dispositivo.

## Flujo de Full Dúplex Authentication®

Los usuarios tienen la opción de disfrutar de una experiencia con un solo dispositivo o con dos dispositivos. Los dispositivos duales son más seguros ya que requieren un dispositivo para mostrar el diálogo de inicio de sesión y un segundo dispositivo de autenticación, con una aplicación de autenticación para recibir y aceptar la notificación automática. En el caso de un dispositivo dual, un usuario iniciará el proceso de inicio de sesión ingresando un nombre de usuario en el primer dispositivo.

El nombre de usuario se envía al servidor NoPass. Si el nombre de usuario ha sido registrado, el servidor NoPass enviará instrucciones de autenticación al portal registrado. Cuando el usuario ingresa el nombre de usuario, aparecen una imagen y un número en el dispositivo de autenticación registrado. El servidor NoPass enviará una notificación automática con las credenciales y una carga de mensaje que contiene instrucciones sobre cómo mostrar la misma imagen y número.



Full Dúplex Authentication® se completa cuando la aplicación en el dispositivo registrado autentica el servidor de autenticación y acepta la carga útil del mensaje para mostrar la imagen y el número. Si la aplicación acepta las credenciales del servidor en el dispositivo del usuario, la aplicación descifrará y generará la misma imagen y número en el dispositivo de autenticación. Estas imágenes y números cambian cada 30 segundos, por lo que la autenticación Full Dúplex

Authentication® se repite hasta que el usuario responde al mensaje en su dispositivo de autenticación. La configuración en el servidor NoPass puede limitar los intentos de inicio de sesión para evitar que el usuario acepte accidentalmente la notificación push (fatiga de push). El usuario también puede rechazarlo si no inició el intento de inicio de sesión.

Antes de devolver la confirmación de que las credenciales del usuario son válidas al servidor NoPass™, se pueden ejecutar factores de autenticación adicionales. Esto puede incluir verificar la presencia de un token HW como Yubikey o biométrico. Las opciones admitidas dependen principalmente del dispositivo y de las opciones disponibles. Por ejemplo, los dispositivos iPhone y Android tienen datos biométricos integrados, como reconocimiento facial y huellas dactilares.

Otro ejemplo podría ser cuando se necesita Yubikey para proteger una máquina virtual o una estación de trabajo compartida. Después de realizar la verificación de seguridad local, la aplicación de autenticación devolverá las credenciales al servidor NoPass y, si son válidas, el servidor NoPass™ le indicará al servidor de terceros o al portal web que permita al usuario ingresar a la aplicación.

# Como Full Dúplex Authentication® Previene Ataques Cibernéticos Comunes

La mayoría de los ciberataques implican el robo de las credenciales de un usuario. Las organizaciones han logrado avances significativos en el avance y la implementación de herramientas que evitan que los delincuentes utilicen malware sofisticado y vulnerabilidades conocidas para violar una empresa. Por lo tanto, los malos actores han recurrido a herramientas y métodos menos sofisticados y se han dirigido al eslabón más débil de la seguridad: los humanos. Full Dúplex Authentication® proporciona protección adicional contra ataques de ingeniería social porque siempre requerirá que el servicio de autenticación solicitante se autentique ante el usuario. A continuación, se muestran algunos tipos de ataques cibernéticos y cómo Full Dúplex Authentication® los frustra y detiene.

- **Prevención de Phishing:** Full Dúplex Authentication® introduce desafíos y respuestas dinámicas a lo largo del proceso de autenticación. Requerir interacción en tiempo real entre el usuario y el servidor Full Dúplex Authentication® mitiga la efectividad de los ataques de phishing, ya que los credenciales estáticos (contraseñas, tokens, etc.) por sí solos son insuficientes para una autenticación exitosa.
- **Browser-en-Browser Mitigación de ataques:** La comunicación bidireccional en Full Duplex Authentication® permite la verificación constante de la legitimidad del navegador del usuario. Cualquier intento de manipulación o inyección de código no autorizado se detecta rápidamente, lo que evita ataques de navegador en navegador.
- **Resistencia a ataques de proxy no autorizados:** Full Dúplex Authentication® verifica constantemente la autenticidad y los orígenes del canal de comunicación. Esta resiliencia interrumpe las tácticas empleadas en los ataques de proxy no autorizados, evitando la interceptación y manipulación no autorizada de datos.

## Business Impact

Un estudio por el Ponemon Institute, patrocinado por IBM, descubrió que en 2023, el costo medio de una filtración de datos fue de 4,5 millones de dólares. Como se señala en el DBIR de Verizon para 2023, la mayoría de las filtraciones de datos utilizan a los humanos como vector de ataque. Esto se debe a que los humanos son el eslabón más débil de la cadena de seguridad.



En 2023 el costo medio de una filtración de datos fue de **4,5 millones de dólares**.

Ponemon Institute

Además de la posible pérdida por acceso no autorizado, existen costos operativos asociados con la contraseña y la autenticación multifactor que depende del hardware.

Debido a los riesgos inherentes asociados con el uso de contraseñas, estas deben cambiarse periódicamente; las mejores prácticas impulsan un cambio cada 90 días. Esto puede costarle a una organización hasta una hora-hombre de empleado por cada contraseña cada año.

Cuando los dispositivos MFA de hardware se pierden o son defectuosos, reemplazar cada dispositivo aumenta el costo operativo. Las aplicaciones Full Dúplex Authentication® se pueden implementar en un dispositivo que el empleado ya tenga. Esta aplicación ejecutará al menos dos factores de autenticación, lo que reducirá significativamente los costos operativos asociados con otras herramientas MFA.

## Conclusión

A medida que evolucionan las amenazas cibernéticas, se hacen imprescindibles medidas de seguridad innovadoras. Full Dúplex Authentication®, como se describe en la [patente estadounidense 11.245.526](#), está a la vanguardia de las soluciones de autenticación modernas y proporciona una defensa dinámica y sólida contra el phishing, el navegador en el navegador y los ataques de proxy maliciosos. La implementación de esta tecnología innovadora y galardonada es crucial para salvaguardar la integridad y la confidencialidad de las interacciones en línea en un panorama digital en constante cambio. Full Dúplex Authentication® permite eliminar contraseñas en el flujo de autenticación, y esto no solo simplifica el flujo de autenticación sino que también reduce los costos operativos asociados con la administración de contraseñas.

Visite [la Página Web de Identité](#) para aprender mas sobre nuestras soluciones MFA.

Conecte con nosotros en [LinkedIn](#) para recibir noticias en los dominios de seguridad y gestión de identidad.

[Haga clic](#) aquí para contactar con nuestro departamento de ventas y solicitar demostraciones.